Secure architecture - Firewall tests

Outlines

Working tests

Check parameters

PACKET SCANNER : reads packets and displays data to users

$\rightarrow$ Ethereal, Snort, Tcpdump

PACKET GENERATOR : sends packets parameterized by users

$\rightarrow$ Netcat, Nmap, Hping

Working tests

Check parameters

PACKET SCANNER : reads packets and displays data to users

→ `Ethereal`, `Snort`, `Tcpdump`

PACKET GENERATOR : sends packets parameterized by users

→ `Netcat`, `Nmap`, `Hping`

Firewall discovering

- guess IP@ from a name

→ *fw.societe.com*

- search in newsgroups
- search for firewalls responding to specific commands

UDP rules discovering

UDP : no specific traffic

⇒ no response from target: either the UDP service is disabled, or the request has been denied by the firewall.

A port is closed

```
$> hping -2 -p 30000 -c 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50): udp mode set
ICMP Port Unreachable from ip=192.168.3.50
```

Firewall hides information

```
$> hping -2 -p 30001 -c 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50): udp mode set
ICMP Port Unreachable from ip=192.168.1.40
```

UDP rules discovering

UDP : no specific traffic

⇒ no response from target: either the UDP service is disabled, or the request has been denied by the firewall.

A port is closed

```
$> hping -2 -p 30000 -c 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50): udp mode set
ICMP Port Unreachable from ip=192.168.3.50
```

Firewall hides information

```
$> hping -2 -p 30001 -c 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50): udp mode set
ICMP Port Unreachable from ip=192.168.1.40
```

UDP rules discovering

UDP : no specific traffic

$\Rightarrow$ no response from target: either the UDP service is disabled, or the request has been denied by the firewall.

A port is closed

```
$> hping -2 -p 30000 -c 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50): udp mode set
ICMP Port Unreachable from ip=192.168.3.50
```

Firewall hides information

```
$> hping -2 -p 30001 -c 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50): udp mode set
ICMP Port Unreachable from ip=192.168.1.40
```

TCP rules discovering

- no response = filtering without ▸ Reset TCP
- response = ICMP ⇒ may contain information about rules
- response = *Reset TCP* with IP@'s target
  - the attacker thinks she has passed through the firewall...
  - even if the destination port is closed.
- ▸ Examples

TCP rules discovering

- no response = filtering without Reset TCP
- response = ICMP ⇒ may contain information about rules
- response = *Reset TCP* with IP@'s target
  - the attacker thinks she has passed through the firewall...
  - even if the destination port is closed.
- Examples

TCP rules discovering

- no response = filtering without Reset TCP
- response = ICMP ⇒ may contain information about rules
- response = *Reset TCP* with IP@'s target
  - the attacker thinks she has passed through the firewall...
  - even if the destination port is closed.
- Examples

TCP rules discovering

- no response = filtering without ▸ Reset TCP
- response = ICMP ⇒ may contain information about rules
- response = *Reset TCP* with IP@'s target
  - the attacker thinks she has passed through the firewall...
  - even if the destination port is closed.
- ▸ Examples

Firewalking

- Principle: use TTL to discover filtering rules
- the targets receives packets whose TTL changes to 0 after going through the firewall

$\rightarrow$ the router next to the firewall returns *TTL exceeded* with information about the target

$\Rightarrow$ every packet sent will return an error

- the method works if a firewall is detected, if there is an active router and if *TTL exceeded* packets are not filtered out

Firewalking

- Principle: use TTL to discover filtering rules
- the targets receives packets whose TTL changes to 0 after going through the firewall

$\rightarrow$ the router next to the firewall returns *TTL exceeded* with information about the target

$\Rightarrow$ every packet sent will return an error

- the method works if a firewall is detected, if there is an active router and if *TTL exceeded* packets are not filtered out

Firewalking

- Principle: use TTL to discover filtering rules
- the targets receives packets whose TTL changes to 0 after going through the firewall

$\rightarrow$ the router next to the firewall returns *TTL exceeded* with information about the target

$\Rightarrow$ every packet sent will return an error

- the method works if a firewall is detected, if there is an active router and if *TTL exceeded* packets are not filtered out

Firewalking

- Principle: use TTL to discover filtering rules
- the targets receives packets whose TTL changes to 0 after going through the firewall

→ the router next to the firewall returns *TTL exceeded* with information about the target

⇒ every packet sent will return an error

- the method works if a firewall is detected, if there is an active router and if *TTL exceeded* packets are not filtered out

Fooling the firewall with ports

Some firewalls “believe” that an official port is always used by packets of the associated protocol

A classical scan will not pass

```
$> hping -p 30000 -c 1 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50) : NO FLAGS are set
ICMP Port Unreachable from ip=192.168.3.50
```

Using an official port fools the firewall

```
$> hping -s 53 -k -p 30000 -c 1 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50) : NO FLAGS are set
len=46 ip=192.168.3.50 flags=RA seq=0 ttl=254 id=15332
```

Fooling the firewall with ports

Some firewalls "believe" that an official port is always used by packets of the associated protocol

A classical scan will not pass

```
$> hping -p 30000 -c 1 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50) : NO FLAGS are set
ICMP Port Unreachable from ip=192.168.3.50
```

Using an official port fools the firewall

```
$> hping -s 53 -k -p 30000 -c 1 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50) : NO FLAGS are set
len=46 ip=192.168.3.50 flags=RA seq=0 ttl=254 id=15332
```

Fooling the firewall with ports

Some firewalls “believe” that an official port is always used by packets of the associated protocol

A classical scan will not pass

```
$> hping -p 30000 -c 1 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50) : NO FLAGS are set
ICMP Port Unreachable from ip=192.168.3.50
```

Using an official port fools the firewall

```
$> hping -s 53 -k -p 30000 -c 1 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50) : NO FLAGS are set
len=46 ip=192.168.3.50 flags=RA seq=0 ttl=254 id=15332
```

Shell shoveling

- Principle: use legitimous ports accepted by the firewall to discuss with the target to make it open a connexion to the outside
- Firewalls are often too laxist for exiting connections

Shell shoveling

- Principle: use legitimous ports accepted by the firewall to discuss with the target to make it open a connexion to the outside

- Firewalls are often too laxist for exiting connections

Exiting a protected zone

Encapsulate IP packet with a cleared-to-exit protocol (*tunneling*)

- IP over HTTP (HTTPtunnel, `HTun`, `HTTP-TUNNEL`)
- IP over SSL (`Stunnel`) $\rightarrow$ cyphered tunnel
- IP over DNS (`NSTX`)
- IP over ICMP (`Loki`, `Icmptunnel`)
- IP over SMTP (`MailTunnel`)

A tool for monitoring firewalls

WWW.ATHENASECURITY.NET

Offers free tools to:

- test rules
- scores the firewall according several factors
- search your rulebases based on address or service ranges with a browser
- ...

Figures

Reset TCP

Back

Principle

- Bit "reset" (`RST`) = 0 most of the time
- If emitter sends a packet with `RST` = 1, dest. kills the connection.

→ Useful if computer A crashes during connection: dest. B continues to send packets that A will receive after reboot, without remembering the previous connection ⇒ A sends `RST` = 1 to alert B.

Attack or not?

- A hacket could spoof A's @ and send `RST` = 1 to B
- But some softwares use this to stop malware attacks...

Finding TCP rules

Back

Filtered port with sending of *Reset TCP* by firewall

$> hping -p 30001 -c 1 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50): NO FLAGS are set
len=46 ip=192.168.3.50 flags=RA DF seq=0 ttl=255 id=0

Non filtered port

$> hping -p 30001 -c 1 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50): NO FLAGS are set
len=46 ip=192.168.3.50 flags=RA DF seq=0 ttl=254 id=40819

Finding TCP rules

Back

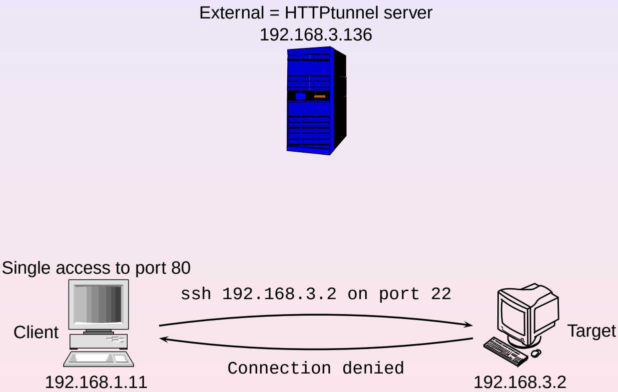
Filtered port with sending of *Reset TCP* by firewall

$> hping -p 30001 -c 1 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50): NO FLAGS are set
len=46 ip=192.168.3.50 flags=RA DF seq=0 ttl=255 id=0

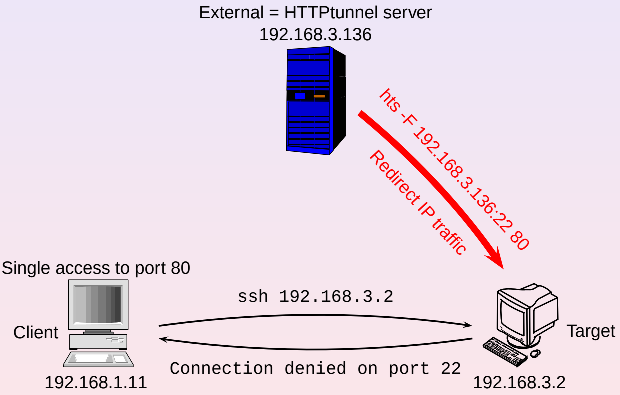
Non filtered port

$> hping -p 30001 -c 1 192.168.3.50
HPING 192.168.3.50 (eth0 192.168.3.50): NO FLAGS are set
len=46 ip=192.168.3.50 flags=RA DF seq=0 ttl=254 id=40819

HTTPtunnel 1/3



HTTPTunnel 2/3



HTTPtunnel 3/3

Back